



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



CVE-2026-48558 SimpleHelp RMM Exploitation Detection Package

Detection Engineering Package

Classification	TLP:CLEAR
Published	2026-07-21
Version	1.0
Author	Lost Boys Cyber
Report Type	Detection Engineering Package

TLP:CLEAR | Lost Boys Cyber | CVE-2026-48558 SimpleHelp RMM Exploitation Detection Package - Detection Engineering Package

Published: 2026-07-21 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Source Intelligence Linkage
3. Behavior Coverage Matrix
4. Detection Package
 - 4.1. Sigma
 - 4.2. Microsoft Defender KQL
 - 4.3. YARA
 - 4.4. Suricata
 - 4.5. Hunt
5. Validation Plan
6. False Positives and Tuning
7. Analyst Handoff

CVE-2026-48558 SimpleHelp RMM Exploitation Detection Package

1. Executive Summary

CVE-2026-48558 reporting describes SimpleHelp Remote Monitoring and Management authentication-bypass exploitation with follow-on TaskWeaver loader and Djinn Stealer deployment. This detection package turns the source vulnerability intelligence report into operator-ready defensive analytics for RMM servers and managed-service environments.

The package is intentionally behavior-focused. It does not attempt to reproduce the exploit. Instead, it validates detection logic around the operational outcomes defenders should be able to see: SimpleHelp service processes launching shell/script/archive/transfer tools, suspicious TaskWeaver/Djinn artifact strings, and HTTP transfer behavior consistent with staged payload retrieval.

2. Source Intelligence Linkage

Field	Value
Source report	`LBC-VTI-2026-108`
Source path	`reports/vulnerabilities/LBC-VTI-2026-108_cve-2026-48558-simplehelp-rmm-authentication-bypass-exploitation`
Priority	Critical for exposed or privileged SimpleHelp RMM deployments
Primary risk	Untrusted actor obtains management access, stages loader/stealer payloads, and pivots toward credential theft or ransomware preparation

3. Behavior Coverage Matrix

Behavior	ATT&CK	Analytic	Telemetry	Validation
Exposed management software exploitation leading to service-context activity	T1190	Sigma + KQL process detection	Endpoint process telemetry	Structural validation
RMM service launches suspicious shell/script/transfer/archive tools	T1059 / T1105	Sigma + KQL process detection	EDR process telemetry	Structural validation
TaskWeaver/Djinn staging artifact strings appear on disk or in collected content	T1105 / T1005	YARA artifact triage	File/content scanning	`yara` fixture scan
HTTP transfer pattern for staged SimpleHelp follow-on payload	T1105	Suricata rule	HTTP/proxy/packet telemetry	`suricata -T` and PCAP replay
Privileged/remote session followed by suspicious payload execution	T1078 / T1059	KQL hunt	Authentication + endpoint telemetry	Structural validation

4. Detection Package

4.1. Sigma

`detections/sigma/simplehelp-rmm-suspicious-child-process.yml`

Detects suspicious child processes and command-line indicators spawned by SimpleHelp service/application context. Tune parent image names to the exact SimpleHelp service names in the environment.

4.2. Microsoft Defender KQL

`detections/kql/simplehelp-rmm-post-exploitation-process.kql`

Finds SimpleHelp-linked parent process activity that launches PowerShell, command shells, archive utilities, transfer tools, or TaskWeaver/Djinn-related command-line content.

4.3. YARA

`detections/yara/simplehelp\_taskweaver\_djinn\_artifacts.yar`

Scans collected scripts, dropped files, memory strings, or triage bundles for SimpleHelp + TaskWeaver/Djinn + transfer/download strings. This is a triage rule, not a malware-family classifier.

4.4. Suricata

`detections/suricata/simplehelp-taskweaver-http.rules`

Detects a synthetic but realistic HTTP request using a TaskWeaver-style user-agent to fetch a SimpleHelp-path payload from `simplehelp-updates.example.net`. Replace the host/path/user-agent logic with observed environment indicators before production deployment.

4.5. Hunt

`hunts/kql/simplehelp-rmm-session-to-payload-correlation.kql`

Correlates SimpleHelp-related hosts, remote/service logons, and suspicious process execution. Use it after patching or exposure discovery to find pre-remediation abuse.

5. Validation Plan

Test	Fixture	Expected Result	Status
Sigma simplehelp suspicious child process structural validation	`validation/fixtures/process-events.jsonl`	Sigma YAML parses and required fields exist	Planned
Defender KQL SimpleHelp post-exploitation process smoke	`validation/fixtures/process-events.jsonl`	KQL structural validation passes	Planned
SimpleHelp session-to-payload correlation hunt smoke	`validation/fixtures/process-events.jsonl`	KQL structural validation passes	Planned
YARA TaskWeaver/Djinn fixture scan	`validation/fixtures/taskweaver-djinn-artifact.txt`	Rule compiles and fixture matches	Planned
Suricata TaskWeaver HTTP PCAP replay	`validation/fixtures/simplehelp-taskweaver-http.pcap`	Rule syntax passes and PCAP replay produces alert	Planned

6. False Positives and Tuning

- Confirm the canonical SimpleHelp service binary and parent process names in each environment.
- Suppress known patching, backup, or support scripts that legitimately launch PowerShell or archive utilities from RMM context.

- Treat YARA hits as triage leads unless corroborated by endpoint/network telemetry.
- Replace synthetic Suricata host/path/user-agent values with known-good or observed-bad values before production blocking.

7. Analyst Handoff

1. Inventory SimpleHelp servers and confirm patch status.
2. Run the KQL detection and hunt across at least 30 days of endpoint/authentication telemetry.
3. Apply the Sigma logic in SIEM/EDR translation pipelines after environment-specific parent-process tuning.
4. Run the YARA rule over collected suspicious files, support-tool directories, and incident-response triage bundles.
5. Use the Suricata rule as a validation template for HTTP payload retrieval logic, not as a final production IoC rule without observed indicators.